

Database Security

Name: Ethan Krul

Class: Isin 325

Date: March 27, 2026

Introduction

This is the outline for the database security policy for the organization with 1,500 employees and annual revenues of \$250 million, expected to grow at 10% per year. The organization utilizes Microsoft SQL Server for its internal systems, which include accounting, forecasting, planning, transactional systems, and data warehouses. Also, the organization uses a third-party cloud-based Human Resources system.

The purpose of this policy is to ensure the confidentiality, integrity, and availability of all database systems by adding a defense in depth strategy. Used to protect from physical, network, and database environments for external threats and insider risks,

Defense in depth.

The defense in depth is a security strategy that uses multiple layers of protection rather than just one form of protection. If one layer fails, the additional layers continue to provide protection. The layers include physical security, network security, database security, access control, and auditing/logging. By using these layers, it reduces the chance of unauthorized access, data breaches, and system compromise.

Security Management.

User Account Management

All users must have unique login credentials. Shared accounts are strictly prohibited. Access to systems and databases must follow the principle of least privilege, meaning users are only granted the minimum level of access necessary to perform their job functions. Role-based access control (RBAC) will be implemented to simplify management and improve consistency.

Password Policies

Passwords must meet strong composition requirements, including a minimum length of 12 characters and the use of uppercase letters, lowercase letters, numbers, and special characters. Passwords will expire every 90 days, and accounts will be locked after five unsuccessful login attempts to prevent brute-force attacks.

Employee Lifecycle Management

Access control must be tightly managed throughout the employee lifecycle. New employees are granted access only after formal approval. When employees change roles, their access must be reviewed and updated. Upon termination, all access must be immediately revoked. Administrative passwords should be changed when key personnel leave the organization.

Remote Access

Remote access is only permitted through secure Virtual Private Network (VPN) connections. Multi-factor authentication (MFA) is required for all remote users. Access may also be restricted based on IP address ranges to further enhance security.

Vendor and Third-Party Access

Third-party vendors, including the cloud-based HR provider, must adhere to strict access controls. Vendor access should be limited, monitored, and restricted to only the data necessary for their services. Secure communication methods such as encrypted connections must be used at all times.

Physical Security

Physical security measures are important to protect the hardware that supports database systems. On-premise database servers must be located in secured data centers with restricted access. Security controls include locked doors, badge access systems, surveillance cameras, and environmental protections such as fire suppression and temperature control.

For the cloud-based HR system, physical security is managed by the cloud provider. However, the organization must ensure that the provider meets recognized security standards such as SOC 2 or ISO 27001 and regularly review compliance reports.

Network Security

Network security plays a critical role in protecting database systems from unauthorized access. A multi-tier architecture must be implemented, separating the web server, application server, and database server. It is a significant security risk to host a database server on the same server as a web server, as this increases exposure to external threats.

Firewalls must be used to control traffic between network layers. Only required ports should be open, and access to database servers should be restricted to authorized systems. Internal network segmentation should be used to isolate sensitive systems.

Additionally, organizations must be cautious when using domain-based security. While single sign-on provides convenience, it can also grant excessive privileges if not properly managed. Administrative access should be tightly controlled and monitored.

Database Security

Server-Level Security

Server-level security controls access across all databases on a server. Only authorized personnel, such as database administrators (DBAs), should be granted high-level roles such as system administrator or security administrator. These roles must be assigned carefully due to their extensive privileges.

Database-Level Security

Database-level security ensures that users only have access to specific databases. Access must be granted explicitly, and users should not have automatic access to all databases on a server.

Role-Based Security

Roles are used to simplify access management. For example, a role such as “CustomerServiceRep” can be created and assigned permissions to perform specific tasks. Users are then assigned to roles rather than being granted permissions individually. If needed, additional restrictions can be applied using the DENY command to override permissions.

Object-Level Security

Users should not be granted direct access to tables whenever possible. Instead, access should be provided through views and stored procedures. This approach limits exposure to sensitive data and provides better control over how data is accessed and modified.

DBO Access

The database owner (dbo) has full control over a database. This level of access should be restricted to DBAs in production environments. Developers may have elevated access in test environments but should not retain such privileges in production.

Application Security

Applications accessing the database must use secure authentication methods. Hardcoding credentials within applications is prohibited. Database access should be restricted to approved applications to prevent unauthorized access outside of controlled environments.

Access Control

Access control mechanisms ensure that only authorized users can access specific data. The principle of least privilege must be enforced at all times. Sensitive data, such as HR and financial information, requires stricter access controls.

Encryption should be used to protect data both at rest and in transit. Technologies such as Transparent Data Encryption (TDE) and Secure Sockets Layer (SSL)/Transport Layer Security (TLS) should be implemented to safeguard sensitive information.

Auditing and Logging

All database activity must be logged and monitored. This includes login attempts, data modifications, and administrative actions. Logs should be reviewed regularly to identify suspicious behavior.

Automated alerts should be configured to notify administrators of potential security incidents, such as repeated failed login attempts or unauthorized access attempts. Logs must be retained for at least one year and stored securely to prevent tampering.

Backup Security

Backup systems must be secured as part of the overall database security strategy. All backups must be encrypted to protect sensitive data. Backup files should be stored in secure locations, including both on-site and off-site or cloud-based storage.

Access to backups must be restricted to authorized personnel, such as DBAs. Backup storage systems must follow the same security controls as live systems to prevent unauthorized access or data breaches. Regular testing of backup integrity and recovery processes is also required.

Insider Threat Considerations

Insider threats pose a significant risk to database security. Employees, contractors, or vendors with legitimate access can misuse their privileges either intentionally or unintentionally.

To mitigate this risk, the organization must implement monitoring systems to track user activity. Separation of duties should be enforced to ensure that no single individual has complete control over critical systems. Regular access reviews must be conducted, and all access must be revoked immediately upon termination.

Conclusion

In conclusion, securing database systems requires a comprehensive and layered approach. By implementing a defense-in-depth strategy, the organization can protect its critical data assets from both external and internal threats. This policy integrates physical, network, and database security controls, along with strong access management and auditing practices.

As the organization continues to grow, maintaining and evolving these security measures will be essential to ensuring data protection, regulatory compliance, and overall business continuity.

Cybersecurity-

The podcast explains that cybercrime is a massive global issue that operates like modern warfare, affecting governments, businesses, and individuals worldwide. Cybercriminal activity is not limited to one region, but is spread internationally, with both state-linked and independent actors involved. The podcast discusses how countries such as Russia, China, North Korea, and Iran are often mentioned due to their involvement or tolerance of cyber operations, but the United States is also a significant source of cybercrime activity. The point is that cyber power does not always match economic power, as smaller nations or even individuals can have outsized influence in cyberspace.

A major concern discussed in the podcast is intellectual property theft, where ideas and inventions are stolen and replicated, often destroying small businesses that cannot compete with mass production. This highlights how cybercrime directly impacts innovation and economic stability. The discussion also emphasizes the difficulty of controlling cybercrime due to weak international regulation, inconsistent enforcement, and companies often delay disclosure of breaches.

From a personal security perspective, the podcast recommends the importance of layered cybersecurity defenses. Recommended practices include keeping routers updated, changing default passwords, separating guest and private networks, and using tools like VPNs for added protection. Strong password management is also critical, with advice ranging from password managers to securely storing high-risk credentials offline. The podcast encourages users to reduce financial risk by limiting funds in online accounts and using dedicated accounts for purchases.

The podcast also warns about common cyber scams, especially emotionally manipulative schemes like romance scams, where attackers build trust over time before requesting money. These scams are dangerous because they exploit human emotions rather than technical weaknesses. Other risks include phishing emails, where users are advised to avoid clicking suspicious links and instead mark messages as spam. Individuals are also encouraged to limit personal data exposure online by using alternate emails, avoiding unnecessary personal details, and being cautious about what is shared on social media.

Overall, the podcast highlights that cybersecurity is a shared responsibility. Since data breaches are common, individuals must assume their information may already be exposed and focus on reducing risk and limiting damage. Cybersecurity is described as an evolving field that requires adaptability, problem-solving skills, and constant awareness of new threats.